

Risikoanalyse og risikostyring

Sune Andersen (SUAN@)

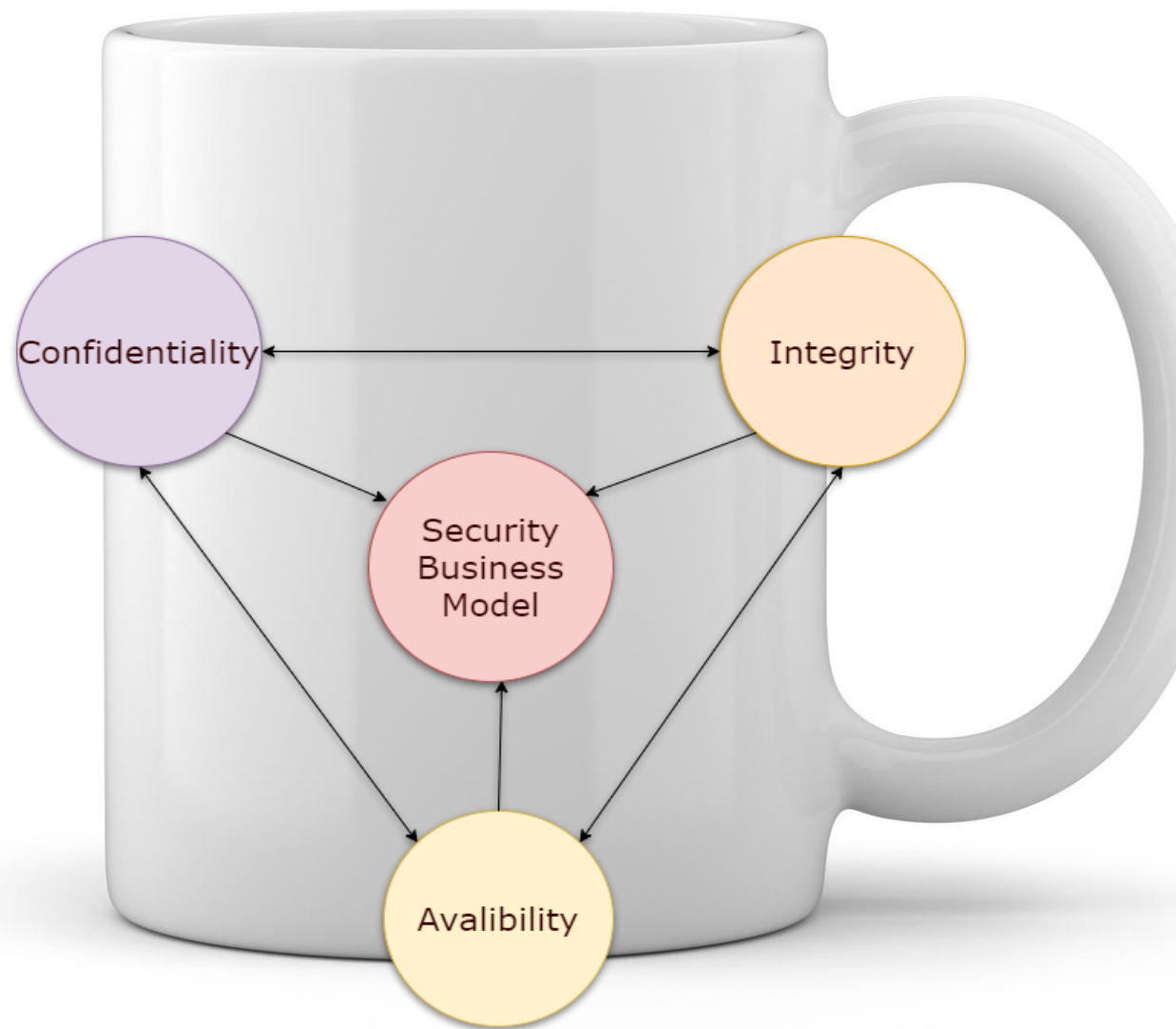


I dag :

- CIA+
- Risiko og vurdering
- Hvad er risiko og hvad er risiko ikke
- Trusler for virksomheden
- Frameworks CIS kontrollerne
- Frameworks ISO27000/27001/27002
- Politikker
- Business Continuity Plan (BCP)
- Patch management
- Hacking Hvad er lovligt og ulovligt.
- Danske Organisationer til anmeldelse



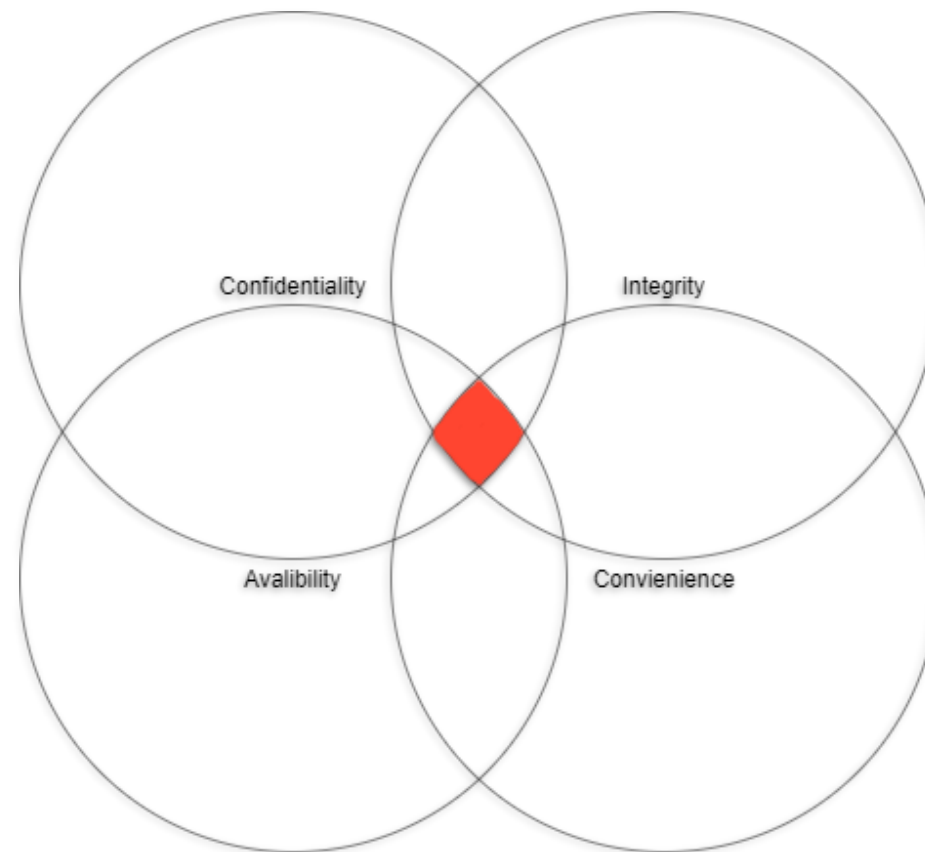
CIA triaden og frameworks



Udfordringen her

Man overser ofte brugeres evner til at omgå systemer.

Er det ikke nemt, så finder folk selv løsningerne.



RisikoVurdering

Regler og retningslinjer i virksomheden

- Risikominimering
- reduktion til acceptable risici
 - dem kan man leve med, ved at udføre kontroller imod dem
 - overføre dem til anden organisation (Som en måde at forsikring eks PCI DSS til leverandør)
 - Holde sig til en plan og definere det indenfor en tidsramme
- Ensrettede regler og måder at udføre opgaver på.
- Hvad er accepteret og hvad er ikke accepteret.
(Policies og forankring i teknologien)



RisikoVurdering

Minimere

- Nedetid
- Kriminalitet og tyveri
- Jura mæssige problemer (GDPR)
- Intellektuelle rettigheder /
forretningshemmeligheder
- Hackere og misbrug
- mv.



Sikkerhed og forventningsafstemning

Sikkerhed

Hvad skal vi beskytte?

Hvilke trusler og risici tager vi højde for?

Er sikkerheden tilstrækkelig til kundens behov?

Sikkerhed er ikke kun teknologi – det handler også om mennesker, penge og processer.

Forventningsafstemning

Hvad forventer ledelsen, at løsningen beskytter mod?

Hvad kan løsningen **ikke** beskytte mod?

Aftal tydeligt ansvar mellem kunde og leverandør

Undgå antagelser – få krav og forventninger på skrift

Pointen med billedet:

“Det er ikke nok at bygge et hegn – vi skal være enige om, hvad hegnet skal beskytte imod.”



Client Expectations



Client Budget

Risiko betydning

Risiko

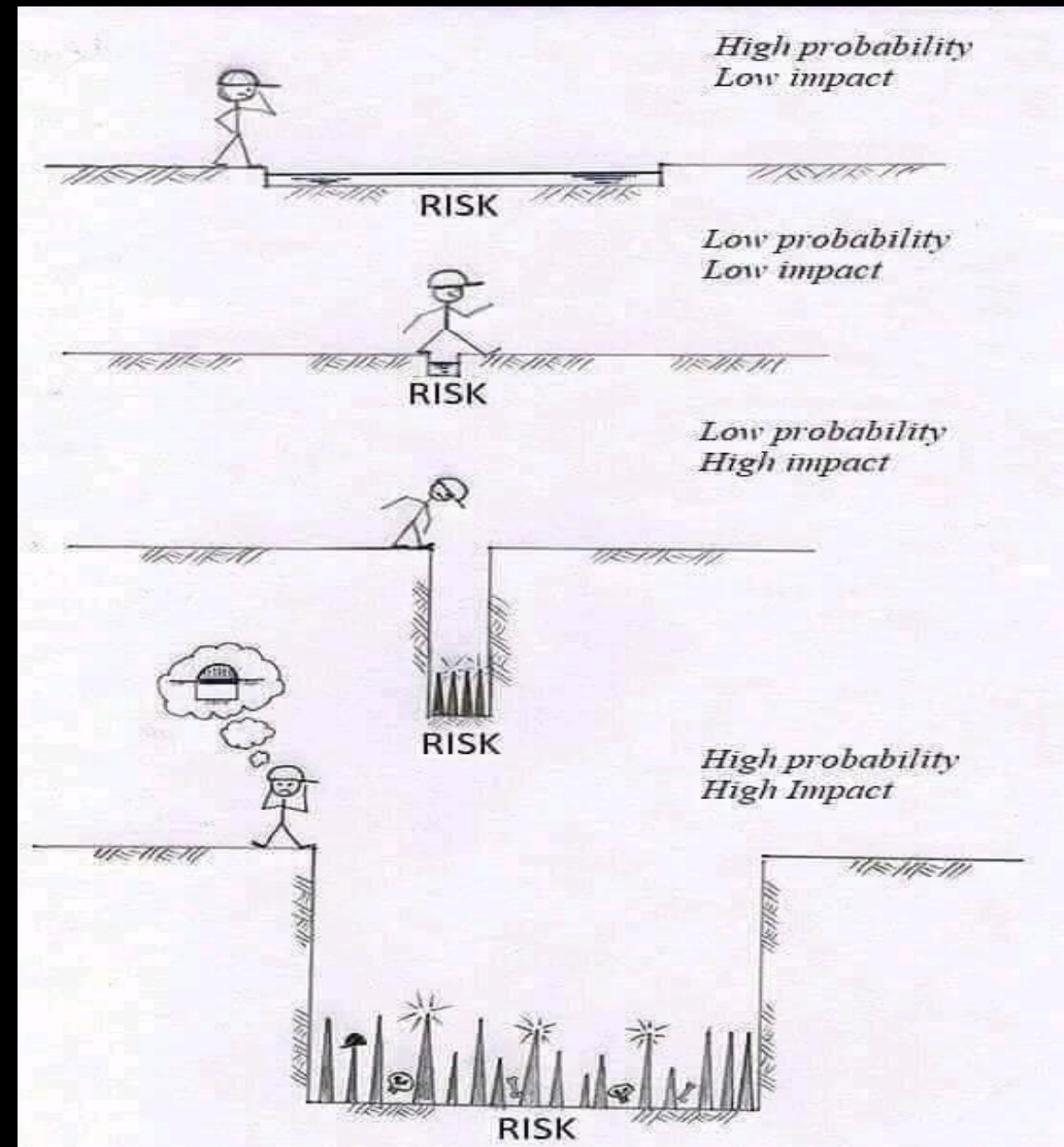
Mulighed for et negativt resultat; mulighed for skade, tab, fare el.lign

Kalkuleret risiko

Risiko der på baggrund af grundige overvejelser betragtes som værd at løbe

Tage/løbe en risiko

Handle i bevidstheden om at resultatet kan blive negativt



Udregning og eksempel

CIS Sec. Beregning

Risk-Reduction ROI

$$\text{ROI} = \frac{(\text{reduction in risk '\$'} - \text{cost of control})}{\text{cost of control}}$$

$$\text{Reduction in risk} = \text{annualized rate of occurrence} \times \text{expected monetary loss for a single event} \times \text{reduction in probability of risk occurrence with the implemented control}$$



Example: Phishing Attacks

Annualized rate of occurrence = 5 per year

Expected monetary loss for a single event = \$35,000

Reduction in probability of risk occurrence with implemented control = - 85%

Cost of control = \$25,000

Calculating Risk-Reduction ROI

$$\text{Reduction in risk} : 5 \times \$35,000 \times 0.85 = \$148,750$$

$$\text{ROI} : \frac{(\$148,750 - \$25,000)}{\$25,000} = 4.95$$

$$\text{Savings per year} : \$25,000 \times 4.95 = \$123,750$$



Eksempel på udregning fra CIS: <https://www.cisecurity.org/blog/the-one-equation-you-need-to-calculate-risk-reduction-roi/>

og fra risk management guru: <https://riskmanagementguru.com/residual-risk-scoring-matrix-example.html/>

Sikkerdigital.dk

Sikkerdigital.dk er en portal, hvor Digitaliseringsstyrelsen og Erhvervsstyrelsen har samlet vigtig viden om informationssikkerhed til både borger, virksomhed eller myndighed.

Om sikkerdigital.dk

Bag sikkerdigital.dk står Digitaliseringsstyrelsen og Erhvervsstyrelsen, samt en række samarbejdspartnere.

På sikkerdigital.dk kan borgere, virksomheder og myndigheder finde viden, vejledning og konkrete værktøjer til en sikker digital hverdag.

Sikkerdigital.dk er skabt ud fra et ønske om at højne kendskabet til cybertruslerne og kontinuerlig forbedre bevidstheden om hvordan de imødegås med sikker adfærd.

Det er derfor vores ønske at andre hjælper med at sprede indholdet og de gode råd.

[Læs mere om hvordan, du må bruge vores indhold](#)

Udregning og eksempel

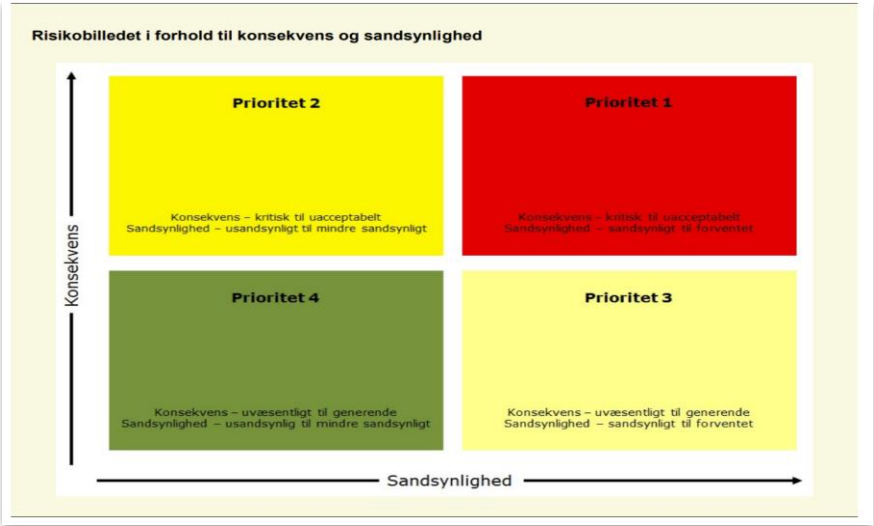
Risiko faktor	Sandsynlighed (S)	Konsekvens(K)	S * K	Prioritet
System 1	4	2	8	2
System 2	2	3	6	3
System 3	5	2	10	1
System 4	1	5	5	4

Risk Assessment Table				
		Severity of Harm (Impact)		
		Low (L)	Medium (M)	High (H)
Likelihood	High (H)	3	4	5
	Medium (M)	2	3	4
	Low (L)	1	2	3

Eksempel på udregning fra CIS: <https://www.cisecurity.org/blog/the-one-equation-you-need-to-calculate-risk-reduction-roi/>

Risikoanalyse

Risiko = Sandsynlighed x konsekvens



IMPACT	Risk Management Actions		
Significant - Financial Loss > \$5MM - Stakeholder faith impacted and lasts > 18 months - Isolated or Multiple Loss of Life - Multiple events of fine, fraud or legal action - Complete system crash with loss of critical data - Inability to recruit, retain staff to operate - Labour disruption that impacts graduation	Considerable Management Required	Must manage and monitor risks	Extensive management essential
Moderate - Financial Loss < \$5 MM - Stakeholder faith impacted and lasts 6-12 months - Significant injury to one or more - Isolate incidents of fine, fraud, or legal action - System crash during a peak period - Difficulties in recruiting and retaining staff - Labour disruption that impacts operations of any duration	Risks may be worth accepting with monitoring	Management effort worthwhile	Management effort required
Minor - Financial Loss < \$500,000 - Stakeholder faith impacted and lasts < 6 months - Isolated injury - Civil or criminal action threatened - System off-line periodically during non-peak periods	Accept risks	Accept but monitor risks	Manage and monitor risks
	Low > 36 months	Medium 18 to 36 months	High 12 to 18 months
	LIKELIHOOD		

God video og se: <https://youtu.be/Ula3TG8QS7g>

Risikoanalyse

Kvantitativ grundet det er lidt "gætværk" om der sker noget. Viden er oftest baseret på hvad der er sket i verden.

Besværliggøre derfor udarbejdelsen af en ALE (Annual Loss Expectancy)

Vi vil gerne have Kvalitative data, som er data vi selv har skabt.

Hvad er risiko?

I ISO27000:2013 betegnes risiko som noget neutralt - *effect of uncertainty on objectives* – eller på dansk som effekten af usikkerhed på målsætninger. En risiko kan således både være en god eller negativ ting - alt efter hvad målsætningen er. Den almindelige forståelse af begrebet på dansk er dog, at risiko er negativt ladet, altså at noget uønsket sker.

Risikoen måles ved at bedømme, hvor stor sandsynlighed der er for, at en trussel vil kunne påvirke en sårbarhed og skabe en risiko, og hvor store konsekvenser det kan have. Konsekvenserne er de forretningsmæssige konsekvenser, dvs. hvilken betydning det vil have for organisationen og dens målsætninger. Sandsynligheden tager udgangspunkt i de trusler og sårbarheder, som findes.

Risikoanalyse

Risk appetit

Tænk tilbage på din sidste tur til lufthavnen. Hvor tidligt ankom du? Nogle mennesker vælger at ankomme på det sidste mulige tidspunkt for at reducere deres ventetid, selvom de nogle gange risikerer at misse deres fly.

Andre holder sig på den sikre side og planlægger at ankomme 3 timer før den planlagte afgang for at sikre sig, at ingen uforudsete omstændigheder, såsom tung trafik, ødelægger deres ferie. Forskellige mennesker er villige til at tolerere forskellige risikoniveauer, når de fanger et fly.

God video og se om Risiko med AI : <https://youtu.be/0oeD2Wf25wY>

Eksempler

Hvad er risiko og hvad er risiko ikke?

Hvad er risiko ikke

Et par eksempler

(Optræder ofte i de dokumenter for de enkelte systemer og eller hvis der er en risiko afdeling, ellers vil dette være i sikkerhedsafdelingen)

- Netværks stabilitet for at få systemet til at virke
- Manglende viden om service eller system (fx cloud eller SAAS systemer)
- For lidt medarbejdere til at udføre opgaven

Hvad er risiko så!

Et par eksempler

(Optræder ofte i de dokumenter for de enkelte systemer og eller hvis der er en risiko afdeling, ellers vil dette være i sikkerhedsafdelingen)

- Systemet kan ikke opdateres på grund af leverandøren, så serveren vil være Windows server 2012
- Leverandøren kan kun logge på via RDP direkte fra nettet og ikke via VPN
- Leverandøren har ikke penetration testing af deres system, som vi benytter og har vigtige data liggende på.
- Vi benytter en cloud tjeneste, hvor vi har mange systemer kørende, og leverandøren kan ikke redegøre for hvilke adgange de har til data. (dette er det man kalder en virksomheds risiko, da dette har indflydelse på flere systemer på tværs af virksomheden og ikke kun et enkeltstående system)

Hvad er angrebsfladen

- Er jeres e-mail / koder lækket?
- Genbruger i kodeord
- mobiltelefonen, hvordan har i sikret denne? bliver den opdateret?
- Benyttes 3 parts software?
- IOT enheder, som fx kamera, NAS, vægt, LED pære mv. (uPNP på hjemmenet?)
- Cloud services (ikke i bogens afsnit)
- Software som ikke er opdateret (Auto update – hvis muligt!)
- Manglende planer for håndtering af nedetid
- Udefrakommende påvirkninger (malware, phishing, CEO svindel (BEC) mf.
- Der kan nævnes meget mere.

Du skal identificere dine risici og beskytte dem.

Trusler – Phishing / Scammers

Andre vil have dine oplysninger !

- Navn, adresse, e-mail og telefon nummer
- Adgange til kritiske systemer og vejen dertil
- Udnyttelse af privilegerede rettigheder (Administrative rettigheder)
- Adgang til pengene og overførsler
- Adgang til ressourcer (på nettet og internt, til fx deling af malware, billeder...)

Ofte anvendt til at skabe adgang til Virksomheder , Penge og afpresse personer.

Eller Kontakt svindle ("Hej jeg er fra banken / politiet")

Der tages udgangspunkt i lækage materiale fra internettet.



God video og se om Phishing og bekæmpelse. <https://www.youtube.com/watch?v=4PB5ITj420Q>

Opgave

Kig dig selv over skulderen (30 min opgave)

Udveksle information med en makker og se hvad man kan finde på vedkommende.

Husk at være flink ;-) finder man materiale som kan være noget personen har glemt eller ikke vidste, så lad være med at dele det med andre end din makker!

Hvad kan du finde dig om selv på nettet ? (google dig selv!)

NB! Husk etikken... finder i noget, hjælp med at fjerne det !

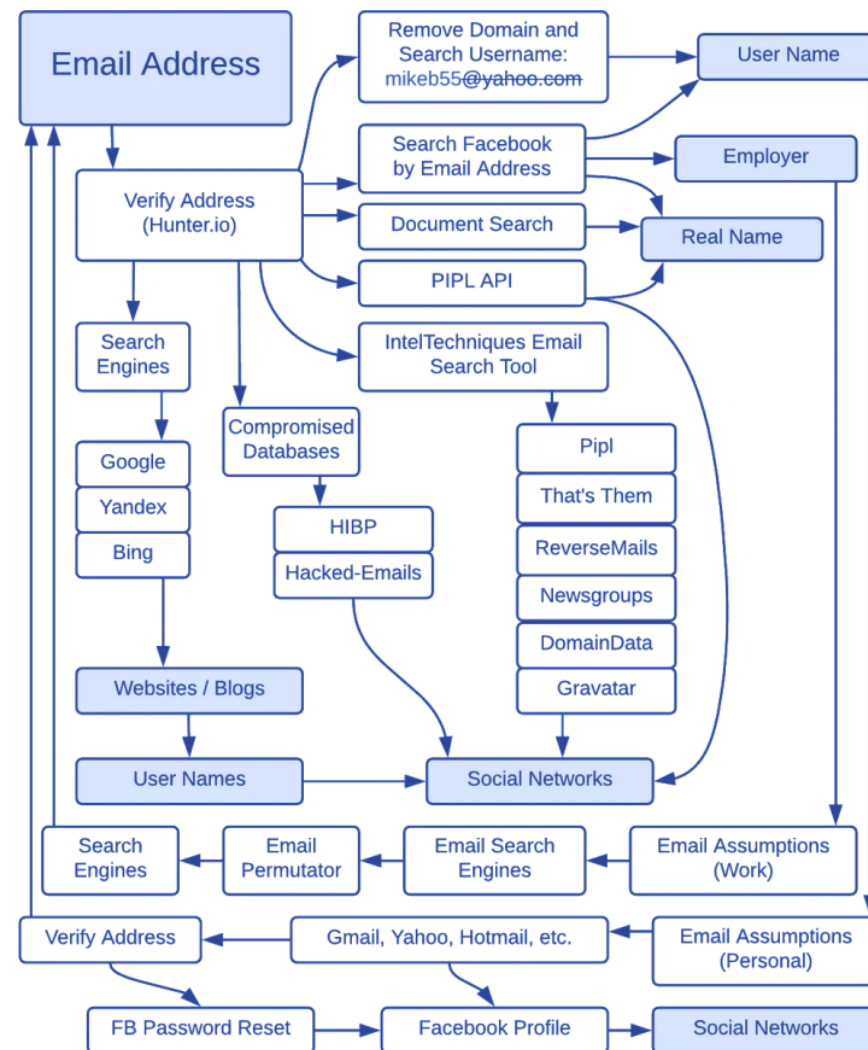
- Dit navn – cpr. Nr (ikke med din makker)
- Telefonnummer
- e-mail (ligger dit password et sted?) (<https://haveibeenpwned.com>)
- Måske et billede fra din mindre pæne side ?

Formål

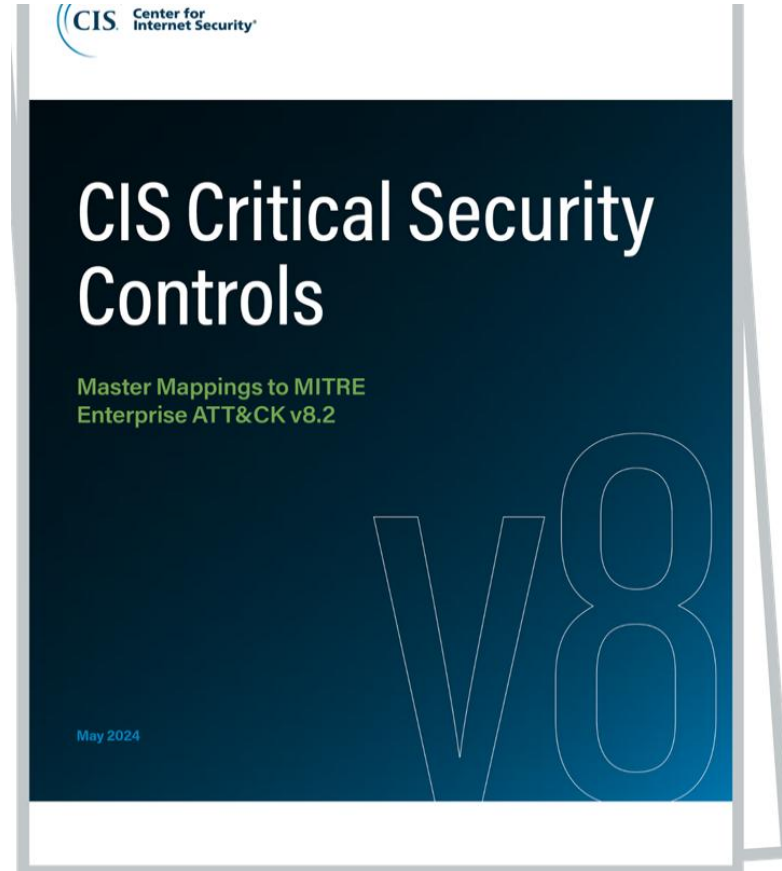
Husk, at når i skal søge job i informationssikkerhedsbranchen.

Så bliver i med stor sandsynlighed udsat for det samme.

At søge efter en person ud fra mailen /navnet kan man gøre på flere måder.



Kilde : How to find information on anyone: The best OSINT tools for people search — MII



Kan hentes via :

<https://www.cisecurity.org/insights/white-papers/cis-controls-v8-master-mapping-to-mitre-enterprise-attck-v82>

Vi skal se
på...



Backup !!

CIS Kontrol v8 består af 18 emner.

10: Malwareforsvar

CSF v1.1 referencer: PR.PT-2 DE.CM-4

CSF v2.0 referencer: DE.CM-03 DE.CM-09

PF v1.0 referencer: PR.PT-P1

Trusler rettet: Forhøjelse af privilegier Sidebevægelse

Kontrolerklæring

Forhindre eller kontrollere installation, spredning og eksekvering af ondsindede programmer, kode eller scripts på virksomhedens aktiver.

[csf.tools Bemærk: Besøg Center for Internetsikkerhed for at få flere oplysninger om de kritiske sikkerhedskontroller.]

Underkontroller

10.1: Implementer og vedligehold anti-malware-software

Implementer og vedligehold anti-malware-software på alle virksomhedsaktiver.

10.2: Konfigurer automatiske anti-malware-signaturopdateringer

Konfigurer automatiske opdateringer til anti-malware-signaturfiler på alle virksomhedsaktiver.

10.3: Deaktiver Autorun og Autoplay for flytbare medier

Deaktiver autorun og autoplay auto-execute funktionalitet for flytbare medier.

10.4: Konfigurer automatisk anti-malware-scanning af flytbare medier

Implementer automatisk scanning af flytbare medier for malware.



Windows / Linux Admin
skal.....

Kilde : Kontroller 10 – Malware. <https://csf.tools/reference/critical-security-controls/v8-1/csc-10/>

188	10	10			Malware Defenses	<i>Prevent or control the installation, spread, and execution of malicious scripts on enterprise assets.</i>
189	10	10,1	Devices	Protect	Deploy and Maintain Anti-Malware Software	Deploy and maintain anti-malware software on all enterprise assets.
190	10	10,2	Devices	Protect	Configure Automatic Anti-Malware Signature Updates	Configure automatic updates for anti-malware signature files on all ente
191	10	10,3	Devices	Protect	Disable Autorun and Autoplay for Removable Media	Disable autorun and autoplay auto-execute functionality for removable m
192	10	10,4	Devices	Detect	Configure Automatic Anti-Malware Scanning of Removable Media	Configure anti-malware software to automatically scan removable medi
193	10	10,5	Devices	Protect	Enable Anti-Exploitation Features	Enable anti-exploitation features on enterprise assets and software, whi Microsoft® Data Execution Prevention (DEP), Windows® Defender Explo System Integrity Protection (SIP) and Gatekeeper™.
194	10	10,6	Devices	Protect	Centrally Manage Anti-Malware Software	Centrally manage anti-malware software.
195	10	10,7	Devices	Detect	Use Behavior-Based Anti-Malware Software	Use behavior-based anti-malware software.

Mailen fra cissecurity
Som giver adgang til
Pdf med Benchmark

Thank you for completing the CIS Benchmarks PDF download form. We have received and approved your request, and you will find the link to the download page below.

You now have access to all of our CIS Benchmarks PDFs and can download as many as you like.

IMPORTANT:

You must use the same browser to access the download page as you filled out the benchmark form, and you must have cookies enabled. If you have any issues accessing the benchmark reports please let us know at learn@cissecurity.org.

Access PDFs

(Access the Benchmark PDFs)

Used by over 2,000 businesses and organizations around the world, **CIS SecureSuite Membership** provides access to integrated cybersecurity tools, CIS Build Kits, and more.

Want to learn more about how to implement the CIS Benchmarks? **Join our next demo:** www.cissecurity.org/webinar/cis-benchmarks-demo/.



CIS-benchmarks er præskriptive konfigurationsanbefalinger for mere end 25+ leverandørproduktfamilier.

De repræsenterer den konsensusbaserede indsats fra cybersikkerhedseksperter globalt for at hjælpe dig med at beskytte dine systemer mod trusler mere trygt.

NB! Jeg vælger RedHat Linux 9.x efter jeg har åbnet linket i mailen – som er det jeg ved noget om ;-)

Red Hat Enterprise Linux

[HENT BENCHMARK →](#)

Tilgængelige versioner inkluderer:

Red Hat Enterprise Linux 7 (4.0.0) | Red Hat Enterprise Linux 8 (3.0.0) | Red Hat Enterprise Linux 9 (1.0.0) | Red Hat Enterprise Linux 7 STIG (2.0.0) | Red Hat Enterprise Linux 8 STIG (1.0.0) | Red Hat Enterprise Linux 6 (3.0.0) | Red Hat Enterprise Linux 5 (2.2.1)



CIS Red Hat Enterprise Linux 9 Benchmark

v1.0.0 - 11-28-2022

Center for Internet Security (CIS) udgav den første version af CIS Benchmark for RHEL 9 den 28. november 2022, hvilket giver et sæt af 255 anbefalede sikkerhedskontroller organiseret i to forskellige niveauer til RHEL 9-servere og -arbejdsstationer .

Red Hat-ingeniørernes aktive deltagelse bidrager til høje kvalitetsstandarder, der er tilpasset bedste praksis for RHEL, samtidig med at det bringer værdi til Fedora og andre community Linux-distributioner.

The number of Safeguards an enterprise is expected to implement increases based on which group the enterprise falls into.

IG3

IG3 assists enterprises with IT security experts to secure sensitive and confidential data. IG3 aims to prevent and/or lessen the impact of sophisticated attacks.

IG2

IG2 assists enterprises managing IT infrastructure of multiple departments with differing risk profiles. IG2 aims to help enterprises cope with increased operational complexity.

IG1

IG1 is the definition of essential cyber hygiene and represents a minimum standard of information security for all enterprises. IG1 assists enterprises with limited cybersecurity expertise thwart general, non-targeted attacks.



Implementation Group 3

A mature organization with significant resources and cybersecurity experience to allocate to Sub-Controls



Implementation Group 2

An organization with moderate resources and cybersecurity expertise to implement Sub-Controls



Implementation Group 1

An organization with limited resources and cybersecurity expertise available to implement Sub-Controls

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 <u>Collect Audit Logs</u> Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 <u>Activate audit logging</u> Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 <u>Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●



MITRE ATT&CK Mappings:

Techniques / Sub-techniques	Tactics	Mitigations
T1070, T1070.002, T1211, T1562, T1562.001	TA0005	



4.2.1.2 Ensure rsyslog service is enabled (Automated)

Profile Applicability:

- Level 1 - Server
- Level 1 - Workstation

Description:

Once the `rsyslog` package is installed, ensure that the service is enabled.

Rationale:

If the `rsyslog` service is not enabled to start on boot, the system will not capture logging events.

Audit:

Run the following command to verify `rsyslog` is enabled:

```
# systemctl is-enabled rsyslog
```

Verify the output matches:

```
enabled
```

Remediation:

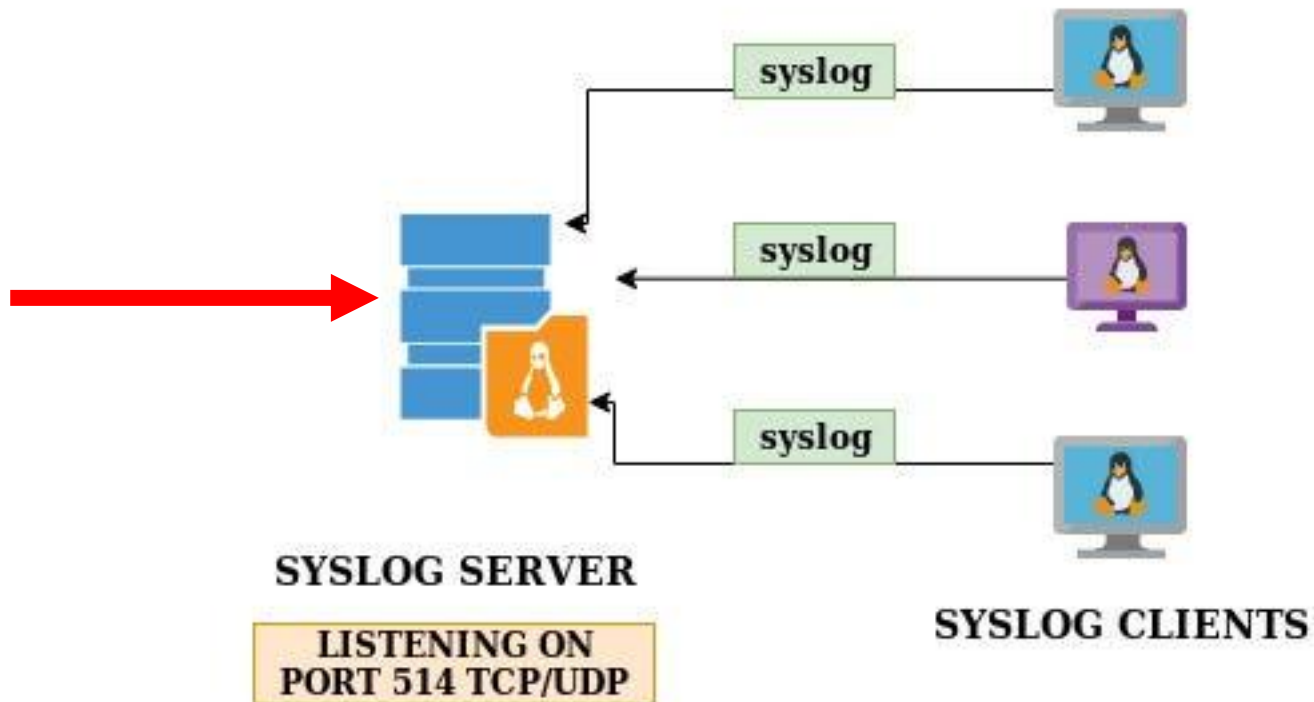
Run the following command to enable `rsyslog`:

```
# systemctl --now enable rsyslog
```

Additional Information:

NIST SP 800-53 Rev. 5:

Husk firewall og
SELINUX!!



Setup Rsyslog på redhat 9 :

https://access.redhat.com/documentation/en-us/red_hat_enterprise_linux/9/html/security_hardening/index

<https://www.matoski.com/article/rsyslog-centralized-logging/>

Nysgerrig?
Spørg løs!



Min Mail
suan@zealand.dk